

Cloud Identity Misconfiguration response

Cloud · **Critical** severity · SOC IR Playbook

Incident type	Misconfiguration - IAM / Access Policy
Severity	Critical
Priority	Critical
Detection sources	CSPM tools, Cloud audit logs, SIEM, IAM policy scans, Threat Intelligence, Red Team findings

Scenario

A misconfigured cloud identity or access control (e.g., overly permissive IAM role, wildcard access policy, unintended trust relationships) is exploited by an internal or external actor to gain elevated access, move laterally or access restricted resources.

MITRE ATT&CK

T1078.004, T1098.001, T1550.001

Preparation

Use least privilege model Enforce granular IAM roles and policy-based access controls Deploy CSPM tools Monitor for identity misconfigurations (e.g., Wiz, Prisma Cloud, Microsoft Defender for Cloud) Enable detailed logging Use AWS CloudTrail, Azure Activity Logs, GCP Audit Logs for tracking IAM events Tag and classify identities Differentiate human vs service identities and apply risk-based monitoring Conduct access reviews Regular audits of IAM roles, trust policies and access keys

Detection & Analysis

Alert triggered CSPM or SIEM alert for excessive permissions, wildcard access ("*") or trust to Everyone Validate misconfiguration Review IAM policy, role assumptions, group memberships and any unusual inheritance Review access logs Determine if the misconfiguration has been exploited (API calls, resource access) Assess affected assets Identify what services or data were accessible using the misconfigured identity

Containment

Restrict or delete misconfigured role/policy Immediately remove or correct the risky configuration Revoke temporary credentials Invalidate STS tokens, API keys, access tokens issued via the misconfigured identity Quarantine affected resources Isolate compromised services or data buckets if suspicious activity is confirmed Notify cloud admin teams Coordinate IAM changes and service validations across cloud accounts or regions

Eradication

Remediate IAM policy Apply corrected policies with scoped permissions, conditions and role boundaries Rotate affected credentials Especially for users, service accounts or cloud-native secrets Validate trust relationships Reconfigure role assumptions and remove unintended cross-account trust Remove unused roles/groups Decommission identities that serve no operational need

Recovery

Restore proper access Re-assign necessary permissions using least privilege principles Monitor reconfiguration Set temporary alerts on updated identities for post-fix behaviour validation Re-enable services After confirming configurations are secure and audit logs show no further misuse Communicate status Provide updates to security, DevOps and cloud platform owners

Lessons Learned & Reporting

Conduct impact analysis Confirm whether data access or privilege abuse occurred and over what period Improve IAM policies Apply service control policies, permission boundaries and conditional logic Update monitoring rules

Add detections for wildcard privileges, new identity creation and cross-account role use Document the incident Include the IAM resource affected, root cause, impacted assets and resolution steps Report if needed To internal stakeholders or regulatory bodies if sensitive data was accessed

Tools typically involved

CSPM tools (e.g., Wiz, Prisma Cloud, Microsoft Defender for Cloud, AWS Config); SIEM (e.g., Splunk, Sentinel, QRadar); Cloud audit logs (e.g., AWS CloudTrail, Azure Activity Logs, GCP Audit Logs); IAM policy scanners (e.g., PMapper, CloudSploit, IAM Access Analyzer); SOAR for automated remediation; Identity governance platforms (e.g., Saviynt, SailPoint, Okta)

Success metrics (SLA targets)

Detection Time <10 minutes for risky IAM change Containment Time <30 minutes from alert confirmation Policy Fix Completion <4 hours for critical misconfiguration Credential Rotation Time <2 hours for affected identities Access Review Coverage 100% of affected identities audited post-incident